

DoubleCheck vNext implementation, audit, and deployment report

Date: 10 August 2026

Repository: github.com/zadworny/doublecheck

Working directory reviewed: /Users/samzadworny/github/doublecheck

Product input: Verified-Recruiter-Badge-Plan.pdf (10 pages)

Blockchain: Stellar testnet / Soroban

Contract: CDY4WIUWUJWDW4AKPTYFXTRONQVVS52PS2ZYFU2S5HEMW2U7LM5KRHKP

1. Executive result

The project was reviewed end to end: repository structure, Rust/Soroban contract, generated ABI client, React/Vite frontend, wallet integration, application/report transport, tests, deployment configuration, documentation, and the supplied product plan.

The original EVM-oriented plan was translated to Stellar without issuing a transferable asset or speculative token. DoubleCheck now models identity, affiliation, and live authority as separate Soroban records. Sensitive verification and complaint evidence remains off-chain; Stellar stores status, signer provenance, bounded public facts, and hashes.

The vNext Wasm was installed and used to upgrade the existing public testnet contract in place. Five demonstration entities and eight claims were preserved. The TypeScript binding was regenerated from the final live specification.

This is a technically deployed testnet release, not a production verification service. Independent audit, real KYC/KYB operations, secure evidence storage, reviewer staffing, appeals, rate limiting, production key custody, indexer/API, and full credential-proof validation remain required.

2. Product model extracted from the plan

The review treated these requirements as non-negotiable:

- A badge must be non-transferable, recipient-consented, revocable, and time-bound.
- Expiry and periodic re-verification must prevent permanent “zombie trust.”
- The chain stores only trust anchors, public status, signer provenance, and hashes.
- ID documents, liveness evidence, KYB reports, references, complaint allegations, and reviewer notes must never be written to an immutable public ledger.
- Recruiter identity, company relationship, and company mandate are different claims.
- A self-asserted mandate must never be presented as company authorization.
- Company-confirmed and issuer-confirmed mandates must remain visibly distinct.
- Public checking must require no wallet or account.
- Share links, QR codes, and embedded badges must resolve current status rather than freeze a “verified” statement.
- Reports must stay private until an authorized review outcome is recorded.
- No speculative token or cash-staking system is required at launch.

3. EVM-to-Stellar translation

Original EVM concept	Implemented Stellar design
Soulbound NFT	Soroban Entity registry entry with no transfer entry point
ERC ownership	Explicit Soroban address authorization and controller consent
Attestation service	First-class Relationship and Mandate records
Burn/revocation authority	Immutable per-badge issuer plus constrained global arbiter
Account abstraction/paymaster	Future passkey smart account and fee sponsorship; Freighter remains current expert path
Public RPC reads	Wallet-free Soroban simulations
Permanent storage assumption	Submitted keepalive, TTL monitoring, and archive restoration plan
On-chain profile/evidence	Off-chain credential with SHA-256 anchor and public status
Token slashing	Public strikes, suspension, withdrawal, and terminal revocation

4. Soroban contract features added or hardened

4.1 Recipient-consented onboarding

- Added PendingEntity records.
- Added propose_entity for a reviewed issuer offer.
- Proposal binds controller, handle, public organization descriptors, credential hash/URI, terms hash, acceptance deadline, and badge expiry.
- Proposal reserves the handle and controller without creating a verified badge.
- Added accept_entity; only the exact intended controller can activate the badge.
- Added cancellation and expired-proposal release behavior.
- Enforced acceptance deadline no later than 30 days and strictly before badge expiry.
- Revalidated pending offers at acceptance to make legacy/stale proposals fail safely.
- Kept coordinated one-step register_entity, but it now requires both issuer and controller auth.

4.2 Badge lifecycle and fixed authority

- Required every badge to have a future expiry.
- Capped badge validity at 400 days.
- Applied expiry at read time without requiring a scheduled transaction.
- Made revocation terminal.
- Stored immutable Entity.issuer as lifecycle authority.
- Metadata replacement, renewal, issuer suspension, revocation, recovery approval, compatible atomic recovery, and issuer-side strikes now require that badge's stored issuer.
- Global admin handover affects future issuance/configuration/upgrades only; it does not seize old issuer cohorts.
- Added tests proving old issuer authority remains valid after admin handover and new admin cannot mutate old badges.

4.3 Controller recovery without a sale-like transfer

- Added three-party recovery:
 1. Current controller proposes exact destination.
 2. Stored issuer approves after recovery/re-verification.
 3. Exact destination accepts.
- Replacing a proposal invalidates prior approval.
- Added public reads for pending and approved destinations.

- Added cancellation by current controller or stored issuer.
- Atomic compatibility rotation requires stored issuer, current controller, and destination auth.
- Badge holder and buyer cannot use contract-assisted holder-only transfer.

4.4 Metadata and privacy validation

- Credential and terms hashes cannot be all-zero placeholders for new records.
- Credential URI must be bounded `https://` or `ipfs://`.
- Only stored issuer may replace the vetted credential anchor.
- Natural-person `display_name`, `domain`, and `jurisdiction` must remain empty on-chain.
- Organization legal name, `domain`, and `jurisdiction` are required.
- Relationship role and mandate scope are required.
- Public handles, text, and URIs reject unsafe controls, bidi overrides/isolates, zero-width formats, and reserved product routes.
- Existing demonstration records remain readable even when they use historical zero hashes.

4.5 Relationships and publication consent

- Relationship signer determines confirmation class.
- Organization-created person relationships start unlisted unless the subject or authorized issuer records publication consent.
- Public frontend omits `public_display=false` relationships from snapshots, lookups, search, feeds, and direct public claim pages.
- Subject can withdraw a claim about themselves.
- Generic status mutation cannot create an undated Ended relationship; `end_relationship` records the required end date.
- Ended and Withdrawn are terminal; changed affiliations require a new record.

4.6 Mandates and authorization

- Mandates support a person or verified agency/organization as representative.
- Organization and representative must differ.
- Every mandate has required scope, start, end, and maximum 366-day window.
- A mandate can stand alone or link to a matching relationship.
- Signer-derived tiers:
 - Representative: `SelfAsserted`.
 - Organization: `CounterpartyConfirmed`.
 - Registry admin/issuer workflow: `IssuerConfirmed`.
- `SelfAsserted` is evidence only and never makes `is_authorized` return true.
- Strict authorization requires:
 - active, unexpired organization badge;
 - active, unexpired representative badge;
 - exact requested pair;
 - live mandate validity window;
 - company- or issuer-confirmed provenance;
 - matching, active, published linked relationship when one is referenced.
- Newer scheduled, withdrawn, expired, or self-asserted mandates do not mask an older usable confirmation.
- Revoking either badge immediately invalidates dependent authorization.

4.7 Safe index capacity

- General history indexes retain up to 512 ids for small-registry browser discovery.
- Added separate exact-pair confirmed-mandate index.

- Self-assertions never consume confirmed capacity.
- Inactive, expired, missing, malformed, and self-asserted entries are pruned.
- Live or scheduled confirmations are never silently evicted.
- Exact pair allows at most 64 relevant confirmations.
- IndexFull rejects a new relevant confirmation atomically when capacity is full.
- Strict authorization shares a 128-record scan budget across new and compatibility indexes.
- Original 512-record strict scan design was rejected after adversarial testing exceeded Stellar protocol footprint limits (747 footprint entries and 373 writes).

4.8 Status authority, complaints, and governance

- Role-aware entity, relationship, and mandate transitions.
- Arbiter can dispute, suspend, withdraw, and add strikes within constrained rules.
- Arbiter cannot revoke entities.
- Arbiter can lift only its own suspension, not issuer suspension.
- Organization cannot clear an arbiter-created dispute/suspension.
- Subject/representative cannot strengthen their own claim through status mutation.
- Mandate Completed/Withdrawn and relationship Ended/Withdrawn are terminal.
- Pause blocks new onboarding and claims but not takedown/withdrawal paths.
- Admin handover remains two-step.
- Material actions emit typed events.

4.9 Stellar TTL and archival operations

- Corrected false assumption that simulated reads persist TTL extensions.
- Added signed, permissionless, cursor-based keepalive.
- Batch size constrained to 1–50 entities/claims.
- Keeper touches entities, claims, relationship/mandate indexes, pair indexes, recovery keys, and relevant storage.
- Added `SC/scripts/keepalive.sh` resumable runner.
- Documented monitoring, fee funding, cursor persistence, and restore-footprint requirements.
- Submitted live testnet keepalive touched all 5 entities and 8 claims and returned `done=true`.

5. Frontend and product features

5.1 Public truth layer

- Reworked chain mapping into effective, ledger-time-aware statuses.
- Added Active, Scheduled, Proposed, Expired, Suspended, Revoked, Withdrawn, Completed, Disputed, Ended, and Unavailable presentation states.
- Self-asserted live mandates display as Proposed, never green Active.
- Added explicit entity state banners and strike/accountability counts.
- Added badge expiry, controller, issuer, verified date, and status details.
- Removed false “everything is organization-confirmed” language.
- Home counters now include only active entities and live confirmed mandates.
- Claim wording distinguishes public/listed evidence from confirmed evidence.
- Timeline no longer invents transition timestamps when event indexing is unavailable.

5.2 Public relationship privacy

- Public registry context filters unpublished relationships defensively.
- Unpublished relationships cannot leak through:

- organization/person pages;
 - latest feeds;
 - search;
 - public claim lookup;
 - linked mandate details.
- Holder console still permits authorized challenge, withdrawal, and publication management because Soroban data remains publicly readable even when omitted from official UI.

5.3 Live refresh and RPC correctness

- Snapshot refreshes every 60 seconds and when tab becomes visible after staleness.
- Expiry uses ledger timestamp instead of visitor device time.
- Trust pages fail closed if registry cannot be read.
- Fixed generated SDK read failure caused by supplying Stellar's impossible null account as publicKey; simulation-only read clients now omit it.
- Added retryable registry error state explaining RPC outage vs archived ledger data.
- Application, standards, and unknown static routes remain available during RPC outage.
- Fixed provider topology so navbar search/controller resolution receives registry context only on chain-backed routes.

5.4 Candidate-facing mandate verifier

- Added /verify organization/representative checker.
- Accepts handle, entity id, domain, or Stellar controller address.
- Evaluates both badges, mandate status, time window, confirmation tier, and linked relationship.
- Scans past unusable newer mandates to find an older live confirmation.
- Calls deployed is_authorized directly.
- Strongest positive verdict requires visible dependencies and direct contract result to agree.
- Self-asserted mandate always receives caution/negative treatment.
- Displays signing key, scope, territory, validity, relationship, claim id, and snapshot time.

5.5 Live badge, QR, and sharing

- Added compact /badge/:handle iframe route outside normal site chrome.
- Badge re-reads current registry state instead of embedding a static result.
- Testnet disclosure states vNext demo and non-production status.
- Added locally generated SVG QR download.
- Added shareable stable handle link.
- Added live iframe snippet for websites.
- Added neutral HTML and Markdown links for email/docs.
- Removed static “Verified on DoubleCheck” copy that could survive revocation.
- Added no-store cache policy for live badge.
- Allowed cross-site framing only for /badge/*; protected other routes from clickjacking.

5.6 Credential anchor verification

- Added manual credential panel on person and organization pages.
- Supports user-triggered public HTTPS fetch and local file comparison.
- Limits credential documents to 512 KiB, including missing-content-length responses.
- Uses 8-second request timeout, no credentials, no referrer, and no redirects.
- Rejects direct local/private URL literals, including IPv4-mapped IPv6 and full IPv6 link-local range.
- Supports exact raw-byte SHA-256 and stable canonical JSON SHA-256.
- Summarizes deliberately disclosed W3C VC 2.0 fields.

- Clearly states hash match proves document integrity only.
- Does not claim proof-suite signature, credential status, holder binding, or selective-disclosure verification.
- IPFS credentials are not sent through a hard-coded gateway; users can compare a disclosed local file.
- Keyed credential panels prevent stale result from one entity appearing under another route.

5.7 New-user application flow

- Added /apply three-stage form.
- Supports:
 - individual recruiter;
 - recruiting agency;
 - hiring company.
- Role-specific fields and readiness checklist cover:
 - ID and liveness;
 - professional profile/history;
 - work email;
 - at least two references;
 - business registration;
 - domain control;
 - code of conduct;
 - company hiring need;
 - organization size and jurisdiction.
- Validates contract-safe, non-reserved preferred handles.
- Accepts optional valid Stellar G... or smart-account C... controller.
- Warns that current Freightier holder console supports G... accounts only.
- Requires terms, privacy, and accuracy consent.
- Submission stays off-chain and explicitly does not create a badge.
- Receipt describes review, proposal, controller acceptance, and final-ledger activation.

5.8 Private application and complaint intake

- Added Vercel Node function at /api/intake.
- Accepts POST JSON only.
- Caps body at 16 KiB for parsed and streaming paths.
- Strictly allow-lists every application/report field.
- Rejects unknown fields and filled honeypot.
- Normalizes NFKC and strips control/format spoofing characters.
- Validates role-specific fields, email, Stellar addresses, handles, consent, categories, and ids.
- Accepts public HTTPS URLs only; rejects localhost, .local, loopback, RFC1918, link-local, ULA, IPv4-mapped IPv6, embedded credentials, and redirects.
- Uses server-only webhook URL and optional bearer token.
- Uses 8-second downstream timeout.
- Uses 80-bit random application/report reference suffixes.
- Returns 202 only after downstream webhook accepts.
- Returns honest 503 when webhook is missing and 502 when downstream fails.
- Never returns a fake reference.
- Never logs submitted personal payload.
- Adds server-controlled intake policy version to forwarded envelope.
- Browser client omits credentials, has 12-second timeout, and preserves field errors.

5.9 Real report workflow

- Replaced fake timer-based success with real API delivery.

- Added report controls to entity and claim pages.
- Sends target type, numeric on-chain target id, display label, category, required contact email, factual details, optional HTTPS evidence link, honeypot, and privacy consent.
- Raw allegations remain private/off-chain.
- UI closes and shows success only after real RPT—... reference.
- Errors explicitly say not to assume receipt without a reference.
- Reports do not automatically flag, suspend, or defame a subject.

5.10 Holder wallet console

- Added /manage expert/testnet Freighter flow.
- Resolves connected Stellar address to current entity controller.
- Supports organization/person relationship attestations.
- Supports company-confirmed and representative-self-asserted mandates.
- Supports person-controlled relationship listing publication/unpublication.
- Supports relationship and mandate withdrawal for either on-chain party, including agency representatives.
- Reads holder indexes and permits direct claim lookup when index discovery is incomplete.
- Normalizes and bounds input.
- Builds canonical detail hash and exact human-readable statement.
- Pins contract, network, controller, nonce/arguments, and expected authorization tree.
- Simulates before wallet prompt.
- Rejects unexpected extra signers.
- Uses Freighter sign/send and reports success only after final ledger confirmation.
- Secret keys never enter the application.

5.11 Routes and availability

Added and integrated:

- /apply
- /verify
- /manage
- /standard
- /badge/:handle
- existing canonical /:handle, entity, claim, search, and /me paths

Route ordering keeps reserved product paths ahead of generic handles. Live badge is chrome-free.

Application/standards/404 routes do not require registry startup. Search degrades safely without a registry provider.

6. Audits and important defects corrected

Contract/security audit findings fixed

- Recipient could receive active badge without consent.
- Mutable global admin effectively controlled old badges after handover.
- Admin-only controller rotation acted like a transfer primitive.
- Subject could replace issuer-vetted credential anchor.
- Self-asserted mandates could satisfy authorization.
- Newer unusable mandate could mask older valid mandate.
- Exact-pair index could silently omit valid confirmed authorization.
- Initial 512-record strict scan exceeded Stellar protocol limits.
- Organization could reactivate subject-withdrawn/arbitrator-held claims.

- Generic relationship status could create Ended without end date.
- Organization could issue mandate to itself.
- Permanent/overlong badges and mandates were possible.
- Public person descriptors and empty trust fields were accepted.
- Format-control text could spoof verifier output.
- Simulated reads were incorrectly documented as durable TTL maintenance.
- Keepalive initially missed strict pair indexes.

Frontend/runtime audit findings fixed

- Read client attempted to load nonexistent GAAAA... account before every simulation.
- `public_display=false` relationships were rendered publicly.
- Future, expired, self-asserted, or dependency-broken mandates could appear green.
- Entity pages omitted explicit suspended/revoked/expired state.
- Home counted inactive/unconfirmed records as verified.
- Report modal claimed success without sending anything.
- Share snippets froze “verified” wording.
- Page snapshot could remain stale for tab lifetime.
- Browser clock, not ledger time, controlled expiry display.
- Credential hash state could leak between reused React route instances.
- Credential response without body stream could bypass size check.
- IPv4-mapped IPv6/link-local credential URLs bypassed local-host check.
- Static route provider split initially disabled navbar search/controller state.
- Static routes initially crashed because shared controls required registry context.
- Agency representative could not withdraw its mandate in frontend despite contract authority.
- Company-created relationship lacked holder publication action.
- Organization/claim wording elevated self-assertions to “confirmed.”
- Live badge framing policy initially conflicted with global clickjacking protection.

Documentation/operations audit findings fixed

- Replaced inaccurate EVM/NFT assumptions with Soroban behavior.
- Documented testnet/source/binding compatibility explicitly.
- Documented private/public data boundary and GDPR limitations without promising full erasure.
- Documented full new-user private case lifecycle.
- Documented agency seats as separate person badges.
- Documented company-signed vs issuer-confirmed mandate distinction.
- Added deployment, upgrade, binding regeneration, TTL, restore, RPC, monitoring, and mainnet gates.
- Added repository ownership and development guides.
- Added security scope, accepted limitations, and private reporting path.
- Added transparent production-status/verification-standard page.
- Removed unverified traction and production-readiness claims.

7. Automated validation

Frontend, API, and credential checks

Check	Result
<code>npm run lint</code>	Passed
<code>npm test</code>	22/22 passed
<code>npm run build</code>	Passed; 267 modules transformed

Check	Result
TypeScript project build	Passed through tsc -b
Production Vite bundle	Passed
JSON configuration parse	Passed

Tests cover canonical JSON, exact/canonical SHA-256, mismatched credentials, disclosed VC summaries, local/private credential hosts, honest missing-webhook response, successful sanitized forwarding, downstream failure, role-specific application schemas, handles, unknown fields, honeypot, consent, complaints, target ids, unsafe URLs, Unicode sanitization, and text bounds.

Soroban checks

Check	Result
cargo fmt --all -- --check	Passed
cargo clippy --workspace --all-targets --all-features -- -D warnings	Passed
cargo test	59/59 passed
stellar contract build --optimize	Passed
Test snapshots	59 generated/validated
Optimized Wasm	60,131 bytes
Exported functions	49
Wasm SHA-256	1ab20ff8c30b0f704b64dee4aed5d1dd111e5b24e33fb612ef9309aef5dc895a

Contract tests cover consent, auth trees, reservations, expiry, natural-person privacy, metadata authority, relationships, mandates, signer provenance, strict authorization, terminal transitions, arbiter ownership, admin handover, three-party recovery, pause, index crowding/saturation, capacity fail-closed behavior, TTL keeper batches, and adversarial masking cases.

Repository checks

- git diff --check: passed.
- jq empty for JSON configuration: passed.
- bash -n SC/scripts/keepalive.sh: passed.
- CI updated to run frontend tests/lint/build and Rust format/clippy/tests/Wasm target build.
- No secrets added to tracked environment examples.

8. Live Stellar testnet deployment evidence

Item	Value
Network	Stellar testnet
Contract id	CDY4WIUWUJWDW4AKPTYFXTRONQQVS52PS2ZYZFU2S5HEMW2U7LM5KRHKP
Admin	GCHCG2376NU6L7ZUTXCWC6A7D4PZMYHHODB7RJM6QRC6FWB5V5H72GQP
Arbiter	GASB4EXRHAYHJM2TXKVBU430VBFX52BA6VGP77VFTEYPLW375724M72V
Wasm install transaction	ec8653b9de0f0045fcf0ff11628ac49eb1ede6ad3d75a9d8c4cc49a0239ace93
Upgrade transaction	b0aaf6f31e942e619b393505f90f15d57c73404e2707bf688b5d3f56758b7940
Keeper transaction	ec63895736389ea488d47a73ea82579db1f47b728e69755788fd18d657396cc7
Preserved state	5 entities, 8 claims

Item	Value
Keeper result	5 entities touched, 8 claims touched, done=true
Live binding	Regenerated from uncached deployed vNext ABI

Post-upgrade smoke verification confirmed:

- all five entity records remained readable and active;
- entity count remained 5;
- claim count remained 8;
- admin and arbiter addresses remained unchanged;
- new pending-entity, controller-recovery, keepalive, and strict authorization exports are present;
- empty pending lookup returns null rather than failing;
- full keeper batch committed successfully.

9. Files and subsystems materially changed

Contract

- SC/contracts/doublecheck-registry/src/lib.rs
- SC/contracts/doublecheck-registry/src/types.rs
- SC/contracts/doublecheck-registry/src/storage.rs
- SC/contracts/doublecheck-registry/src/events.rs
- SC/contracts/doublecheck-registry/src/test.rs
- 59 Soroban event snapshots
- SC/scripts/keepalive.sh
- SC/README.md

Frontend/application

- Route/provider integration in FE/src/App.tsx
- Registry mapping/context in FE/src/data/
- Chain/wallet/write clients in FE/src/lib/
- New Apply, Verify, Manage, Standard, and LiveBadge pages
- New credential/status components
- Updated entity, claim, home, navbar, search, sharing, reporting, and status components
- Regenerated FE/src/contract/registry.ts from live vNext ABI

Server/intake

- FE/api/intake.ts
- FE/server/intake-validation.ts
- Handler, validation, and credential tests
- FE/src/lib/intake.ts

Deployment/docs

- FE/vercel.json
- .github/workflows/ci.yml
- Root, frontend, and contract READMEs
- Architecture, deployment, development, repository, roadmap, traction, and security documentation
- This Markdown report and generated PDF copy

10. Known remaining work

Required before real users

- Configure authenticated INTAKE_WEBHOOK_URL and optional bearer token.
- Add edge/application rate limiting, replay/idempotency control, and abuse protection.
- Build encrypted durable application/complaint case store.
- Add least-privilege reviewer console and audit logging.
- Select and integrate KYC, liveness, KYB, domain, and reference providers/processes.
- Define verification standards, reviewer conflicts, notices, correction, suspension, revocation, complaint, and appeal service levels.
- Add browser issuer proposal, controller acceptance/cancellation, renewal, recovery, and arbiter workflows.
- Add reminders before expiry (recommended 60/30/7 days).

Required before mainnet

- Independent Soroban/frontend security audit.
- Production multisig/HSM-grade admin and issuer custody.
- Separate funded keeper identity and monitored scheduled execution.
- Upgrade timelock/stronger governance decision.
- Production RPC, event indexer/API, reconciliation, monitoring, and incident response.
- Legal basis/DPIA for durable handles, addresses, hashes, and public claim text.
- Decide whether role/departments/scope/territory must move behind off-chain disclosures.
- Full W3C VC proof-suite, issuer key discovery, status, holder binding, and selective disclosure.
- Passkey smart accounts, lost-device recovery, and fee sponsorship.
- Browser extension and enterprise API only after indexed verifier semantics are stable.

11. Honest status statement

DoubleCheck vNext is implemented, tested, bound to the live ABI, and deployed on Stellar testnet. It provides meaningful cryptographic provenance and lifecycle rules. It does not yet provide a production-grade human verification operation. A testnet badge, demo record, application reference, or hash match must not be treated as an accredited identity, legal endorsement, or guarantee of a recruitment interaction.